

Методичка для лабораторной работы

Выявление сетевых атак при помощи анализа журналов операционной системы Ubuntu

Продолжительность: 4 академических часа (2 пары)

Уровень сложности: Средний

Целевая аудитория: Студенты направлений "Информационная безопасность", "Сетевое администрирование"

Цели лабораторной работы

1. Практические навыки:

- Анализ системных журналов Ubuntu для выявления признаков сетевых атак
- Работа с утилитами `journalctl`, `grep`, `awk` для фильтрации логов
- Использование средств активной защиты (`fail2ban`, `ufw`)

2. Теоретические знания:

- Понимание структуры системных журналов Ubuntu
- Изучение признаков SSH-брутфорса, сканирования портов и эксплуатации уязвимостей
- Знакомство с методами реагирования на инциденты

Необходимое программное обеспечение

Компонент	Назначение
Ubuntu 22.04/24.04	Целевая система (виртуальная машина)
Kali Linux	Система атакующего (опционально, можно симулировать на той же машине)
Hydra	Инструмент для симуляции брутфорса

Компонент	Назначение
Nmap	Инструмент для сканирования портов
Wireshark/tcpdump	Анализ сетевого трафика (опционально)

Теоретическая часть

1. Системные журналы Ubuntu: структура и назначение

В Ubuntu основными источниками информации о безопасности являются следующие логи 2 5 :

Файл журнала	Содержание	Признаки атак
/var/log/auth.log	Аутентификация (SSH, sudo, PAM)	Множественные неудачные попытки входа
/var/log/syslog	Системные события, службы	Неизвестные службы, ошибки
/var/log/ufw.log	События файрвола	Блокировки подозрительных IP
/var/log/kern.log	Ядро системы	Подозрительные модули

Журналы в Ubuntu с версии 16.04 также хранятся в **systemd journal** и доступны через команду `journalctl`

2. Основные типы атак и их признаки в логах

SSH-брутфорс (подбор паролей)

- **Признак:** Множество записей `Failed password` от одного IP за короткий промежуток времени
- **Пример строки:**

```
text

sshd[12345]: Failed password for invalid user admin from 192.168.1.100 port 5432
1 ssh2
```

Сканирование портов

- **Признак:** Множество записей в `ufw.log` о блокировке соединений с одного IP на разные порты ¹⁰
- **Пример строки:**

text

```
UFW BLOCK: IN=eth0 OUT= MAC=... SRC=192.168.1.100 DST=192.168.1.7 LEN=60 PROTO=TCP SPT=54321 DPT=80 ...
```

Атаки на веб-приложения

- **Признак:** Множество HTTP-запросов с кодом 404 или ошибками в логах веб-сервера ¹¹
- **Пути:** `/var/log/apache2/access.log` , `/var/log/nginx/access.log`

3. Инструменты анализа и защиты

- `grep` — поиск по паттернам в логах
- `awk` — структурированная обработка текстовых данных
- `journalctl` — работа с системным журналом `systemd`
- `fail2ban` — автоматическая блокировка IP при превышении порога неудачных попыток
- `ufw` — простой фаервол для блокировки подозрительных адресов

Практическая часть

 **ВНИМАНИЕ:** Все действия выполняются в изолированной виртуальной среде. Не запускайте атакующие инструменты в реальных сетях!

Этап 1. Подготовка рабочей среды (30 мин)

Задача 1.1. Проверка SSH-сервера

```
bash
```

```
# Проверка статуса SSH
sudo systemctl status ssh
```

```
# Если SSH не установлен
sudo apt update && sudo apt install openssh-server
sudo systemctl enable --now ssh
```

Задача 1.2. Включение логирования UFW

```
bash
```

```
# Установка и включение UFW
```

```
sudo apt install ufw -y
```

```
sudo ufw enable
```

```
sudo ufw logging on
```

```
sudo ufw logging high # Максимальный уровень логирования
```

Задача 1.3. Установка fail2ban (опционально, будет использован в конце)

```
bash
```

```
sudo apt install fail2ban -y
```

Задача 1.4. Определение IP-адреса

```
bash
```

```
ip a # или ifconfig
```

Запишите свой IP-адрес — он понадобится для настройки атакующей машины.

Этап 2. Мониторинг логов в реальном времени (15 мин)

Задача 2.1. Просмотр логов аутентификации в реальном времени

В первом терминале выполните:

```
bash
```

```
sudo tail -f /var/log/auth.log
```

Во втором терминале выполните несколько SSH-подключений с неверным паролем:

```
bash
```

```
ssh localhost -l testuser
```

```
# Введите неверный пароль несколько раз
```

Вопрос к студентам: Какие записи появились в логе? Обратите внимание на структуру сообщений ¹⁵ .

Задача 2.2. Использование journalctl для просмотра логов SSH

```
bash
```

```
# Просмотр всех логов SSH-службы
```

```
sudo journalctl -u ssh
```

```
# Просмотр логов за последний час
```

```
sudo journalctl -u ssh --since "1 hour ago"
```

```
# Просмотр в реальном времени
```

```
sudo journalctl -u ssh -f
```

Этап 3. Симуляция и обнаружение SSH-брутфорса (60 мин)

Задача 3.1. Создание словаря для брутфорса (на атакующей машине или на той же)

Создайте файл `passwords.txt` со следующим содержимым:

```
text
```

```
admin
```

```
123456
```

```
password
```

```
qwerty
```

```
letmein
```

```
ubuntu
```

```
test
```

Задача 3.2. Запуск атаки Hydra

Вариант А — атака с той же машины (localhost):

```
bash
```

```
sudo apt install hydra -y
```

```
hydra -l admin -P passwords.txt ssh://127.0.0.1
```

Вариант Б — атака с Kali Linux на Ubuntu:

```
bash
```

```
# На Kali (IP атакующего заменить на IP Ubuntu)
```

```
hydra -l admin -P passwords.txt ssh://<IP_UBUNTU>
```

Задача 3.3. Обнаружение атаки по логам

На целевой системе выполните:

```
bash
```

```
# Поиск неудачных попыток входа
```

```
sudo journalctl -u ssh | grep "Failed password"
```

```
# Подсчет количества неудачных попыток
```

```
sudo journalctl -u ssh | grep "Failed password" | wc -l
```

```
# Определение IP-адреса атакующего
```

```
sudo journalctl -u ssh | grep "Failed password" | awk '{print $11}' | sort | uniq  
-c | sort -nr
```

Ожидаемый результат: Вы увидите множество записей Failed password от одного IP-адреса. Команда с awk покажет IP-адрес атакующего и количество попыток ⁷
1 .

Задача 3.4. Выявление успешного входа (если пароль был угадан)

```
bash
```

```
sudo journalctl -u ssh | grep "Accepted password"
```

Вопросы для обсуждения:

1. Какие поля содержит запись о неудачной попытке входа?
2. Как отличить брутфорс от обычной ошибки ввода пароля?
3. Какие дополнительные признаки атаки можно найти в логах?

Этап 4. Симуляция и обнаружение сканирования портов (45 мин)

Задача 4.1. Настройка UFW для обнаружения сканирования

На целевой системе (Ubuntu) убедитесь, что UFW активен и логирование включено:

```
bash
```

```
sudo ufw status verbose
```

```
sudo ufw logging high
```

Задача 4.2. Запуск сканирования портов с помощью Nmap

С той же машины:

```
bash
```

```
sudo apt install nmap -y
nmap -sS 127.0.0.1
nmap -p 1-1000 127.0.0.1
```

С Kali Linux:

```
bash
```

```
nmap -sS <IP_UBUNTU>
nmap -sT <IP_UBUNTU>
```

Задача 4.3. Анализ логов UFW

```
bash
```

```
# Просмотр логов UFW в реальном времени
```

```
sudo tail -f /var/log/ufw.log
```

```
# Поиск блокировок от IP атакующего
```

```
sudo grep "UFW BLOCK" /var/log/ufw.log | grep "SRC=<IP_АТАКУЮЩЕГО>"
```

```
# Статистика по заблокированным IP
```

```
sudo grep "UFW BLOCK" /var/log/ufw.log | awk '{print $10}' | sort | uniq -c | sort -nr
```

Ожидаемый результат: В логах UFW появятся записи о блокировке попыток подключения к закрытым портам ¹⁰ .

Задача 4.4. Использование psad для детектирования сканирования (опционально)

psad — инструмент для анализа логов iptables и обнаружения сканирования ¹⁴ :

```
bash
```

```
sudo apt install psad -y
sudo psad --Analyze-msgs --analysis-fields "SRC:<IP_АТАКУЮЩЕГО>"
```

Вопросы для обсуждения:

1. В чем отличие SYN-сканирования от TCP-Connect сканирования по логам?

2. Почему сканирование портов считается разведывательной активностью?
3. Какие порты чаще всего сканируются злоумышленниками?

Этап 5. Автоматическая защита с помощью fail2ban (45 мин)

Задача 5.1. Базовая настройка fail2ban для SSH

Создайте локальный файл конфигурации ⁶ :

```
bash
```

```
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
sudo nano /etc/fail2ban/jail.local
```

Найдите секцию [sshd] и установите параметры:

```
ini
```

```
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 5
findtime = 600
bantime = 600
```

Где:

- maxretry = 5 — количество неудачных попыток до бана ⁶
- findtime = 600 — временное окно в секундах (10 минут)
- bantime = 600 — время блокировки в секундах (10 минут)

Задача 5.2. Запуск fail2ban и проверка статуса

```
bash
```

```
sudo systemctl restart fail2ban
sudo systemctl status fail2ban
```

```
# Проверка статуса всех джейлов
sudo fail2ban-client status
```

```
# Проверка статуса SSH-джейла
sudo fail2ban-client status sshd
```

Задача 5.3. Тестирование fail2ban

Повторите атаку Hydra (Задача 3.2) снова. После 5 неудачных попыток IP должен быть заблокирован.

```
bash
```

```
# Проверка заблокированных IP
sudo fail2ban-client status sshd
```

Задача 5.4. Использование fail2ban-regex для тестирования фильтров

```
bash
```

```
# Тестирование regex-шаблона на логах
sudo fail2ban-regex /var/log/auth.log sshd
```

Этот инструмент позволяет проверить, правильно ли fail2ban обнаруживает неудачные попытки в логах `12 3` .

Этап 6. Комплексный анализ и оформление отчета (45 мин)

Задача 6.1. Комплексный анализ логов

Выполните следующие запросы и запишите результаты:

```
bash
```

```
# 1. Топ-10 IP с наибольшим количеством неудачных SSH-попыток
sudo journalctl -u ssh | grep "Failed password" | awk '{print $11}' | sort | uniq -c | sort -nr | head -10
```

```
# 2. Распределение неудачных попыток по пользователям
sudo journalctl -u ssh | grep "Failed password" | awk '{print $9}' | sort | uniq -c | sort -nr
```

```
# 3. Попытки входа в нерабочее время (после 20:00)
sudo journalctl -u ssh --since "20:00" | grep "Failed password"
```

```
# 4. Выявление sudo-активности
sudo grep "sudo:" /var/log/auth.log | tail -20
```

Задача 6.2. Ответ на инцидент

По результатам лабораторной работы опишите план действий при обнаружении атаки:

1. **Обнаружение** — какие признаки в логах указывают на атаку?
2. **Анализ** — определение масштаба (IP-адреса, затронутые учетные записи)
3. **Сдерживание** — какие меры можно применить для остановки атаки?
4. **Восстановление** — действия после завершения атаки

Структура отчета

1. Титульный лист (название, ФИО, группа, дата)
2. Цель работы
3. Теоретическая часть (краткий ответ на контрольные вопросы)
4. Ход работы:
 - Для каждой задачи: команды, скриншоты результатов, анализ
 - Выявленные признаки атак с пояснениями
5. Выводы:
 - Какие типы атак были обнаружены
 - Какие методы анализа оказались наиболее эффективными
 - Рекомендации по защите системы
6. Контрольные вопросы (письменные ответы)

Контрольные вопросы

1. В чем разница между файловыми логами (`/var/log/auth.log`) и системным журналом (`journalctl`)?
2. Какие поля в записи о неудачной SSH-попытке позволяют идентифицировать атакующего?
3. Какие типы сканирования портов можно обнаружить через `ufw.log` ?
4. Как `fail2ban` определяет, что IP нужно заблокировать?
5. Почему важно вести мониторинг логов в реальном времени?
6. Какие дополнительные инструменты можно использовать для обнаружения атак (кроме рассмотренных)?